

INTERNSHIP PROGRAM TASK 1

CYBER SECURITY THREAT REPORT

Threat Intelligence & Cybersecurity Awareness Research

PREPARED BY

Sinaz S

ORGANIZATION

Maincrafts

TASK

Task-1 — Cybersecurity Threat Report

DATE

26 August 2026

Table of Contents

- 1. Introduction to Cybersecurity..... 3**
 - 1.1 What is Cybersecurity?.....3
 - 1.2 Importance of Cybersecurity 3
 - 1.3 Current Cybersecurity Landscape.....3
- 2. Modern Cyber Threats — Overview..... 4**
- 3. Threat Analysis 4**
 - 3.1 AI-Powered Phishing Attacks.....4
 - 3.2 Ransomware-as-a-Service (RaaS)5
 - 3.3 Cloud Security Misconfigurations.....6
 - 3.4 IoT Vulnerabilities7
 - 3.5 Zero-Day Exploits8
- 4. Impact Analysis 9**
- 5. Defensive Strategies 9**
- 6. Conclusion & Future Scope 11**
- References 12**

1. Introduction to Cybersecurity

1.1 What is Cybersecurity?

Cybersecurity is the practice of protecting networks, systems, devices, and data from unauthorized access, disruption, or damage. It is often pictured as firewalls and antivirus software, but in practice it covers three layers working together: **the technical controls (encryption, access management, monitoring)**, the processes that govern how those controls are used (patch cycles, incident response plans), and the people who operate within them. Most serious incidents trace back to a weakness in one of the latter two layers rather than a purely technical failure.

1.2 Importance of Cybersecurity

For individuals, cybersecurity protects the things that are hardest to undo once lost — identity, savings, and personal records. For organizations, it protects the ability to keep operating at all. A ransomware infection or a leaked customer database does not just cost money to fix; it can halt production, trigger legal action, and take years to rebuild trust for. The Colonial Pipeline shutdown discussed later in this report is a clear example of how a single compromised account disrupted fuel supply across an entire region.

1.3 Current Cybersecurity Landscape

Two trends define the current threat landscape. First, digital dependency keeps expanding — banking, healthcare, logistics, and everyday appliances now run on connected systems, which multiplies the number of possible entry points for attackers. Second, generative AI has begun reshaping both sides of the fight. Attackers can now produce fluent phishing emails, cloned voices, and even live deepfake video calls with far less effort than before, which is steadily eroding the usual advice of "look for spelling mistakes" or "check if the voice sounds right." At the same time, defenders are using the same class of tools for faster anomaly detection and automated response, so the balance of the landscape is shifting on both fronts simultaneously rather than favoring one side outright.

WHY THIS MATTERS FOR ORGANIZATIONS

Cybercrime is no longer limited to skilled individual hackers. Ransomware kits are rented out as a service, phishing content can be generated automatically, and cloud misconfigurations can expose data without any "attack" in the traditional sense taking place at all. Awareness and preparedness now matter as much as any single security product.

FIGURE 1: THE CYBERSECURITY ECOSYSTEM



Figure 1: Cybersecurity depends on the interaction between people, technology layers, and the policies that govern them.

2. Modern Cyber Threats — Overview

The five threats covered in this report were chosen because they represent distinct categories of risk: one exploits human trust (AI-powered phishing), one exploits the criminal business model itself (Ransomware-as-a-Service), one exploits configuration mistakes rather than software flaws (cloud misconfiguration), one exploits weak device hygiene (IoT), and one exploits the simple fact that no software is ever completely free of unknown flaws (zero-day exploits). Together, they cover most of the ways organizations are actually breached today.

FIGURE 2: THREAT OVERVIEW

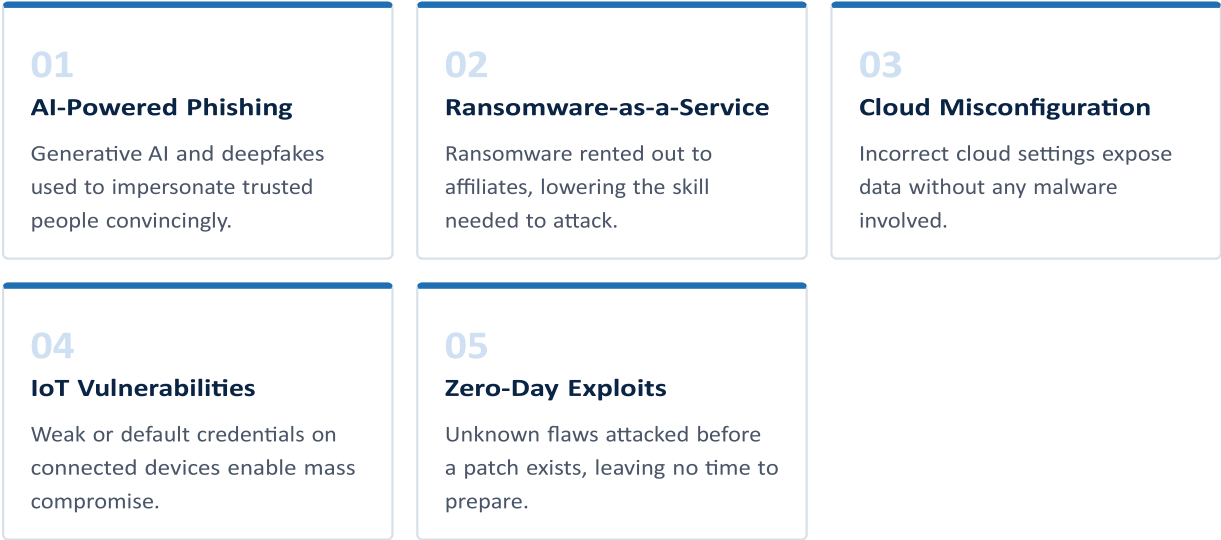


Figure 2: The five threat categories analyzed in this report, spanning human, criminal, configuration, device, and software risk.

Section 3 examines each of these threats individually, following a consistent structure: an overview, how the attack works, why it is dangerous, its impact on individuals and organizations, a real-world case study, preventive measures, and a key takeaway.

3. Threat Analysis

3.1 AI-Powered Phishing Attacks

OVERVIEW

Traditional phishing relies on mass emails with generic greetings and obvious mistakes — the kind of message most people are trained to spot. AI-powered phishing replaces that with generative text, cloned voices, and in the most advanced cases, real-time deepfake video that can impersonate a specific, named individual convincingly.

HOW IT WORKS



Figure 3: Common flow of an AI-powered phishing or deepfake impersonation attack.

WHY IT IS DANGEROUS

It removes the usual red flags people are trained to watch for. A convincing voice or a live video call defeats the standard advice to "call and confirm," since the attacker can simulate that exact call.

Impact on Individuals	Impact on Organizations
Stolen credentials, drained accounts, and impersonation used to target their contacts and colleagues.	Direct financial fraud, wire transfer losses, and reputational damage once the incident becomes public.
Case Study — Arup Deepfake Video Call Fraud (Hong Kong, January 2024)	
A finance employee at the Hong Kong office of Arup, a UK-based engineering firm, received an email appearing to come from the company's CFO requesting a confidential transaction. Skeptical at first, the employee was invited to a video call where the CFO and several other colleagues appeared to be present — all of them were real-time AI-generated deepfakes built from publicly available recordings of company meetings. Convinced, the employee carried out 15 wire transfers totaling roughly HK\$200 million (about \$25.6 million) to five Hong Kong bank accounts. The fraud was only discovered after the employee later checked in with head office about the "secret transaction." Arup's own systems were never breached; the company described the incident as technology-enhanced social engineering rather than a network intrusion.	

PREVENTIVE MEASURES

- **Independent verification:** confirm unusual or urgent payment requests through a separate, pre-established channel — never one supplied within the same call or message.
- **Targeted awareness training:** train staff specifically on AI-driven impersonation, not only outdated phishing red flags such as poor grammar.
- **Dual approval for high-value transactions:** require a second, independent sign-off for transfers above a set threshold.

KEY TAKEAWAY

Technology alone cannot stop this class of attack — it targets trust, not infrastructure. Verification process and awareness training matter more than any single security tool.

3.2 Ransomware-as-a-Service (RaaS)

OVERVIEW

Ransomware-as-a-Service is a criminal business model in which ransomware developers lease their malware, infrastructure, and even victim-negotiation support to "affiliates," who carry out the actual attacks in exchange for a share of the ransom. This division of labor means an affiliate needs only network access, not deep technical skill, to launch a damaging campaign.

HOW IT WORKS



Figure 4: Typical flow of a Ransomware-as-a-Service attack.

RaaS professionalizes cybercrime. Many groups now also steal data before encrypting it ("double extortion"), so paying a ransom no longer guarantees the stolen data will not be leaked anyway, and having backups alone does not remove all the pressure to pay.

WHY IT IS DANGEROUS

Impact on Individuals	Impact on Organizations
Personal data exposure if stolen records are leaked or sold, potentially leading to identity theft.	Operational downtime, ransom costs, recovery expenses, and regulatory scrutiny.
Case Study — Colonial Pipeline Ransomware Attack (United States, May 2021)	
On May 7, 2021, Colonial Pipeline — which supplies a large share of fuel to the U.S. East Coast — discovered a ransomware infection and proactively shut down pipeline operations. The FBI confirmed the DarkSide ransomware-as-a-service variant was responsible. Investigators later found that attackers had entered through a legacy VPN account that lacked multi-factor authentication, using a password believed to have been exposed in an earlier, unrelated data breach. Colonial paid a ransom of 75 Bitcoin (about \$4.4 million at the time) and fully resumed operations on May 12. The U.S. Department of Justice later recovered a portion of the ransom payment. CISA and the FBI subsequently issued a joint advisory on DarkSide with recommended defenses for critical infrastructure operators.	

PREVENTIVE MEASURES

- **Multi-factor authentication:** enforce MFA on all remote access points, especially VPNs, so a single leaked password is not enough on its own.
- **Offline, tested backups:** maintain backups isolated from the main network so encryption alone cannot force a ransom decision.
- **Network segmentation:** separate IT systems from operational/control systems to limit how far an intrusion can spread.

KEY TAKEAWAY

A single unmonitored account without MFA was enough to disrupt fuel supply across an entire region. Basic access hygiene remains one of the highest-value defenses available.

3.3 Cloud Security Misconfigurations

OVERVIEW

Cloud platforms such as AWS, Azure, and Google Cloud hand a large amount of security configuration responsibility to the customer. A single mistake in a firewall rule, storage permission, or identity role can expose sensitive data without any malware or "hacking" in the traditional sense being involved at all.

HOW IT WORKS

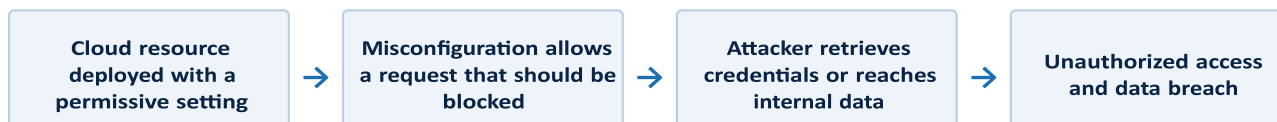


Figure 5: Common flow of a cloud misconfiguration leading to a data breach.

Misconfigurations are often invisible until exploited — there is no obviously "broken lock," just a permission set slightly wider than intended, which can sit unnoticed for months.

Impact on Individuals	Impact on Organizations
Exposure of personal, financial, or identity data collected by the affected service.	Large-scale breach costs, regulatory fines, legal liability, and lasting loss of customer trust.

MUX IT IS DANGEROUS

Case Study — Capital One Cloud Breach (United States, 2019)

A former Amazon Web Services employee exploited a misconfigured web application firewall running in Capital One's AWS environment to carry out a Server-Side Request Forgery (SSRF) attack. This tricked the firewall into requesting temporary credentials from AWS's internal metadata service, and those credentials carried broader permissions than intended. Using them, the attacker accessed and downloaded data from more than 700 Amazon S3 storage buckets — exposing roughly 106 million customer records, including names, credit scores, and Social Security numbers. The intrusion took place in March 2019 but went undetected until July, when Capital One was tipped off after the attacker posted about it publicly. The attacker was arrested and later convicted of computer fraud.

PREVENTIVE MEASURES

- **Least-privilege IAM roles:** ensure no single component has more access than it strictly needs, so one compromised service cannot reach unrelated data.
- **Continuous configuration auditing:** use automated tools to detect drift away from secure baseline settings.
- **Harden metadata access:** restrict or authenticate requests to cloud metadata endpoints (for example, enforcing AWS IMDSv2).

KEY TAKEAWAY

The Capital One breach was not a dramatic "hack" — it was a firewall rule and an over-permissioned role. Least-privilege design matters as much as the firewall itself.

3.4 IoT Vulnerabilities

OVERVIEW

The Internet of Things covers everyday connected devices — routers, cameras, DVRs, and smart appliances — many of which ship with weak security because cost and convenience are prioritized over hardening during manufacturing.

HOW IT WORKS



Figure 6: Common flow of an IoT device compromise leading to botnet enrollment.

Individually low-value devices become collectively powerful once combined into a botnet, and owners rarely notice anything wrong since the device continues to function normally while quietly participating in attacks.

Impact on Individuals	Impact on Organizations
Device hijacked without the owner's knowledge; compromised cameras can also expose personal privacy.	Businesses relying on shared internet infrastructure can be knocked offline even when their own systems are secure.
Case Study — Mirai Botnet and the Dyn DNS Attack (2016)	
The Mirai malware scanned the internet for IoT devices — mainly home routers, IP cameras, and DVRs — using a short list of around 60 common factory default username and password combinations. Because so many devices were never reconfigured from their defaults, Mirai compromised hundreds of thousands of them into a botnet. On October 21,	

WHY IT IS DANGEROUS

2016, that botnet was used to launch a massive distributed denial-of-service (DDoS) attack against Dyn, a major DNS provider, with traffic estimated at over 1 terabit per second. The attack made Twitter, Netflix, Reddit, GitHub, PayPal, and numerous other major sites unreachable for hours across the United States and Europe. The Mirai source code was later leaked publicly, spawning many variants that are still active today.

PREVENTIVE MEASURES

- **Change default credentials immediately:** use unique, strong passwords for every device at setup.
- **Keep firmware updated:** apply security patches promptly and retire devices that no longer receive updates.
- **Network segmentation:** place IoT devices on a separate network segment, isolated from critical systems and data.

KEY TAKEAWAY

Mirai needed no sophisticated exploit — only devices nobody bothered to reconfigure. Manufacturer defaults remain a well-known, published attack surface.

3.5 Zero-Day Exploits

OVERVIEW

A zero-day is a vulnerability that is exploited before the software vendor is aware of it or has released a patch — defenders effectively have zero days of advance warning to prepare.

HOW IT WORKS



Figure 7: Typical lifecycle of a zero-day vulnerability from discovery to patch.

WHY IT IS DANGEROUS

No signature-based defense exists before disclosure, and because so many organizations often rely on the very same shared software component, a single flaw can affect thousands of unrelated systems almost simultaneously.

Impact on Individuals	Impact on Organizations
Any personal device or online service built on the vulnerable software becomes exposed with no warning.	Emergency, unplanned patching efforts and potential compromise across widely used systems.
Case Study — Log4Shell in Apache Log4j (CVE-2021-44228, December 2021)	
Security researchers discovered a critical remote code execution flaw in Log4j, a Java logging library embedded inside an enormous number of enterprise applications and cloud services worldwide. A remote attacker could gain full control of a vulnerable server simply by getting the application to log one specially crafted piece of text. Because Log4j was used so broadly across the software industry, CISA and vendors issued emergency guidance within days, and scanning and exploitation attempts by attackers began within hours of the public disclosure on December 9, 2021. The vulnerability received the maximum possible severity score and required organizations to identify every application using the affected library, often buried deep inside third-party dependencies.	

PREVENTIVE MEASURES

- **Maintain a software inventory:** track dependencies so a vulnerable component can be located quickly when a new flaw is disclosed.
- **Emergency patch management:** apply vendor fixes for critical vulnerabilities immediately rather than waiting for a routine patch cycle.
- **Network monitoring and IDS/IPS:** detect exploitation attempts even before every affected system has been patched.

KEY TAKEAWAY

Shared, widely reused software creates shared risk. A single library buried deep in a dependency chain can affect thousands of unrelated organizations at once.

4. Impact Analysis

The table below summarizes how each threat affects individuals and organizations differently, along with the underlying risk that makes each one significant.

Threat	Individual Impact	Organizational Impact	Main Risk
AI-Powered Phishing	Credential and fund theft; impersonation used against contacts	Financial fraud; reputational damage; regulatory attention	Social engineering that bypasses technical controls entirely
Ransomware-as-a-Service	Personal data exposure if stolen records are leaked	Operational downtime; ransom and recovery costs; legal exposure	Business disruption from a professionalized criminal model
Cloud Misconfiguration	Exposure of personal and financial data	Regulatory fines; breach costs; loss of customer trust	Excessive permissions and unnoticed exposed services
IoT Vulnerabilities	Device hijacked; privacy loss via compromised cameras	Service outages via shared infrastructure (e.g. DNS)	Weak or default credentials at scale
Zero-Day Exploits	Compromise via trusted, everyday software	Emergency response costs; wide, sudden exposure	No advance warning before exploitation begins

A pattern worth noting: only one of these five threats (zero-day exploits) depends on a genuinely unknown technical flaw. The other four — phishing, RaaS, cloud misconfiguration, and IoT compromise — succeed because of process gaps that are already well understood: missing MFA, over-broad permissions, default passwords, and insufficient verification of high-value requests. This is a useful reminder that improving cybersecurity is often less about finding exotic new defenses and more about consistently applying the basics.

5. Defensive Strategies

No single control stops every threat covered in this report. Effective defense works in layers, so that if one control fails or is bypassed, another is positioned to catch the resulting activity.

FIGURE 8: DEFENSE-IN-DEPTH LAYERS

Figure 8: A defense-in-depth model — each layer covers gaps the layer above it may miss.

HOW THESE MEASURES REDUCE RISK

- **Multi-Factor Authentication (MFA):** adds a second proof of identity, so a stolen password alone is not enough to gain access — this single control would likely have blocked the entry point used in the Colonial Pipeline attack.
- **Strong password policies:** reduces the chance that a default or weak credential, like the ones exploited by Mirai, remains usable.
- **Zero Trust:** assumes no user or device is automatically trusted, even inside the network, which limits how far an attacker can move after an initial compromise.
- **Patch management:** closes known vulnerabilities before attackers can use them, which is critical in the days after a zero-day like Log4Shell is disclosed.
- **Endpoint security:** detects malicious behavior on individual devices, ideally catching ransomware activity before it spreads further.
- **Network segmentation:** separates critical systems from general IT, limiting how far ransomware or a botnet foothold can travel, as recommended following Colonial Pipeline.
- **Firewalls and IDS/IPS:** filter and monitor traffic for known-bad patterns, though as the Capital One case showed, a misconfigured firewall can open a hole just as easily as it closes one.
- **Security awareness training:** the primary defense against AI-driven phishing and deepfake calls, since technology alone struggles to catch a well-crafted, human-targeted scam.

- **Secure cloud configuration:** least-privilege permissions and configuration audits prevent the kind of small misconfiguration that led to the Capital One breach.
- **Backup and recovery:** ensures ransomware cannot force a ransom decision when clean, tested, offline backups already exist.
- **Vulnerability management:** ongoing scanning to find exposed IoT devices, unpatched systems, and misconfigurations before attackers do.
- **Monitoring and incident response:** shortens how long an attacker goes unnoticed — the Capital One breach went undetected for roughly four months, largely due to insufficient monitoring of unusual data access.

6. Conclusion & Future Scope

The five threats examined in this report — AI-powered phishing, Ransomware-as-a-Service, cloud misconfiguration, IoT vulnerabilities, and zero-day exploits — span very different techniques, but they share a common thread: each one was made worse by a gap that was preventable, whether that was a missing MFA prompt, an over-permissioned cloud role, a default password, or a delayed patch. This is why cybersecurity has to be proactive rather than reactive. Waiting to respond after an incident is far more expensive, in both cost and trust, than maintaining consistent defenses beforehand.

Continuous monitoring matters because threats do not stay still. New RaaS groups form, new cloud services get misconfigured, and new zero-days are disclosed on an ongoing basis, so a security posture that was adequate a year ago is not guaranteed to hold today. Security awareness training deserves particular attention going forward, since several of the most damaging incidents in this report — especially the Arup deepfake case — succeeded not because a system was hacked, but because a person was convincingly deceived.

Artificial intelligence will likely keep shaping both sides of this field. Attackers are already using it to generate convincing phishing content and real-time impersonation, while defenders are increasingly using it to detect anomalies and respond to incidents faster than manual analysis would allow. For anyone entering the cybersecurity field, this makes continuous learning less of an option and more of a requirement — the tools, threats, and best practices in this report will keep evolving, and staying current is part of the job itself.

References

CISA & FBI. Joint Cybersecurity Advisory AA21-131A: DarkSide Ransomware — Best Practices for Preventing Business Disruption from Ransomware Attacks. May 11, 2021.

<https://www.cisa.gov/news-events/cybersecurity-advisories/aa21-131a>

U.S. Department of Energy. Colonial Pipeline Cyber Incident.

<https://www.energy.gov/ceser/colonial-pipeline-cyber-incident>

CISA. Heightened DDoS Threat Posed by Mirai and Other Botnets. October 14, 2016. <https://www.cisa.gov/news-events/alerts/2016/10/14/heightened-ddos-threat-posed-mirai-and-other-botnets>

CISA. Apache Log4j Vulnerability Guidance. <https://www.cisa.gov/news-events/news/apache-log4j-vulnerability-guidance>

Krebs, B. (KrebsOnSecurity). What We Can Learn from the Capital One Hack. August 2, 2019.

<https://krebsonsecurity.com/2019/08/what-we-can-learn-from-the-capital-one-hack/>

CNN Business. Arup Revealed as Victim of \$25 Million Deepfake Scam Involving Hong Kong Employee. May 16, 2024.

<https://www.cnn.com/2024/05/16/tech/arup-deepfake-scam-loss-hong-kong-intl-hnk>

NIST. Special Publication 800-207: Zero Trust Architecture. August 2020. <https://www.nist.gov/publications/zero-trust-architecture>

OWASP Foundation. OWASP Top Ten — Web Application Security Risks.

<https://owasp.org/www-project-top-ten/>